

Internal Security Audit

Botium Toys - Controls and Compliance Checklist

Audit framework	NIST Cybersecurity Framework - Identify function focus
Scope	Entire security program, including assets, internal processes, controls, and compliance best practices.
Risk score	8 out of 10 - high risk due to missing controls and incomplete compliance alignment.
Prepared date	May 06, 2026

This completed activity reviews the IT manager's scope, goals, risk assessment, control categories, and compliance requirements. The selections below identify whether each control or compliance best practice is currently in place and provide rationale for the assessment.

Executive Summary

Botium Toys is a small U.S. business with a single physical location that also supports a growing online market in the U.S. and abroad. The audit scope covers the organization's entire security program, including IT-managed assets, systems, internal processes, controls, and compliance practices.

The current risk score is 8 out of 10. The highest-risk findings relate to excessive internal access to sensitive data, lack of encryption for credit card data, no IDS, no backups, no disaster recovery plan, weak password requirements, and incomplete asset classification. These gaps create confidentiality, availability, compliance, and business continuity risks.

Botium Toys does have several important controls in place, including a firewall, antivirus software, physical locks, CCTV surveillance, fire detection and prevention systems, and some monitoring of legacy systems. However, the existing control environment needs stronger administrative and technical safeguards to support secure online growth.

Key Audit Findings

- Sensitive data access is too broad because all employees may access internally stored data, including cardholder data and customer PII/SPII.
- Credit card data is accepted, processed, transmitted, and stored internally without encryption.
- Least privilege, separation of duties, backups, disaster recovery planning, and IDS monitoring are not currently implemented.
- Physical security controls are comparatively strong, including locks, CCTV, and fire detection/prevention.
- GDPR breach notification planning and privacy procedures exist, but data classification and inventory work remains incomplete.

Completed Controls Assessment Checklist

Control Category	Control	Status	Rationale	Priority
Administrative / Managerial	Least Privilege	NO	All employees may access internally stored data, including cardholder data and customer PII/SPII. Least privilege has not been implemented.	High
Administrative / Managerial	Disaster recovery plans	NO	No disaster recovery plans are currently in place.	High
Administrative / Managerial	Password policies	YES	A password policy exists, but its requirements are nominal and below current complexity expectations.	Medium
Administrative / Managerial	Separation of duties	NO	Separation of duties has not been implemented.	High
Technical	Firewall	YES	A firewall is in place and blocks traffic based on appropriately defined security rules.	Maintain
Technical	Intrusion detection system (IDS)	NO	The IT department has not installed an IDS.	High
Technical	Backups	NO	The company does not have backups of critical data.	High
Technical	Antivirus software	YES	Antivirus software is installed and monitored regularly by the IT department.	Maintain
Technical	Manual monitoring, maintenance, and intervention for legacy systems	YES	Legacy systems are monitored and maintained, but there is no regular schedule and intervention methods are unclear.	Medium

Control Category	Control	Status	Rationale	Priority
Technical	Encryption	NO	Encryption is not used for credit card information accepted, processed, transmitted, and stored in the internal database.	High
Technical	Password management system	NO	There is no centralized password management system enforcing minimum password requirements.	Medium
Physical / Operational	Locks (offices, storefront, warehouse)	YES	The physical location has sufficient locks.	Maintain
Physical / Operational	Closed-circuit television (CCTV) surveillance	YES	The location has up-to-date CCTV surveillance.	Maintain
Physical / Operational	Fire detection/prevention	YES	Fire detection and prevention systems are functioning.	Maintain

Completed Compliance Checklist

Payment Card Industry Data Security Standard (PCI DSS)

Best Practice	Status	Rationale	Priority
Only authorized users have access to customers credit card information.	NO	All employees may be able to access cardholder data, so access is not limited to authorized users.	High
Credit card information is stored, accepted, processed, and transmitted internally, in a secure environment.	NO	Credit card data is stored and processed internally without encryption and without adequate access restrictions.	High
Implement data encryption procedures to better secure credit card transaction touchpoints and data.	NO	Encryption is not currently used for cardholder data.	High
Adopt secure password management policies.	NO	The existing password policy is weak and there is no centralized password management system.	Medium

General Data Protection Regulation (GDPR)

Best Practice	Status	Rationale	Priority
E.U. customers data is kept private/secured.	NO	Customer data is not sufficiently secured because access controls and encryption are lacking.	High
There is a plan in place to notify E.U. customers within 72 hours if their data is compromised.	YES	The IT department has established a 72-hour breach notification plan for E.U. customers.	Maintain
Ensure data is properly classified and inventoried.	NO	Asset management is inadequate and the organization still needs to identify and classify assets.	High
Enforce privacy policies, procedures, and processes to properly document and maintain data.	YES	Privacy policies, procedures, and processes have been developed and enforced among IT and other employees.	Maintain

Completed Compliance Checklist Continued

System and Organizations Controls (SOC Type 1, SOC Type 2)

Best Practice	Status	Rationale	Priority
User access policies are established.	NO	Least privilege and separation of duties have not been implemented, so user access policies are not adequate.	High
Sensitive data (PII/SPII) is confidential/private.	NO	Employees may be able to access customer PII/SPII, and encryption is not in place for sensitive data.	High
Data integrity ensures the data is consistent, complete, accurate, and has been validated.	YES	The IT department has integrated controls to ensure data integrity.	Maintain
Data is available to individuals authorized to access it.	YES	The IT department has ensured availability, though access control improvements are still required.	Maintain

Recommendations to the IT Manager

Priority	Recommendation	Risk Reduced
1	Implement least privilege, role-based access control, and separation of duties for internal systems, customer records, cardholder data, and administrative functions.	Reduces unauthorized access, insider misuse, account compromise impact, and SOC/PCI/GDPR compliance risk.
2	Encrypt sensitive data at rest and in transit, especially credit card data and customer PII/SPII stored in internal databases.	Improves confidentiality and supports PCI DSS and GDPR expectations.
3	Create a disaster recovery plan and implement scheduled, tested backups for critical systems and business data.	Improves business continuity and recovery from ransomware, system failure, accidental deletion, or physical incidents.
4	Deploy an intrusion detection system and define monitoring procedures for suspicious network activity.	Improves detection of anomalous traffic and potential attacks before they become larger incidents.
5	Strengthen password requirements and implement a centralized password management system with enforcement, recovery workflows, and periodic review.	Reduces account compromise risk and improves employee productivity around password resets.
6	Complete an asset inventory and classification process covering hardware, software, systems, data, legacy systems, and critical business services.	Improves risk visibility, compliance readiness, incident response, and prioritization of controls.
7	Formalize legacy system monitoring with a regular maintenance schedule, documented intervention methods, and escalation criteria.	Reduces operational risk from end-of-life systems that require manual oversight.

Overall Conclusion

Botium Toys has a functional baseline of physical and some technical controls, but the organization is currently exposed to high risk because several critical administrative and technical controls are missing or incomplete. The most urgent improvements are access control, encryption, backups, disaster recovery planning, IDS deployment, password management, and formal asset classification. Addressing these gaps will reduce the likelihood and impact of data exposure, business disruption, and compliance penalties as the company continues to expand its online operations.